

SMART CONTRACT SECURITY AUDIT - GOVDAOCORE

One-Page Visual Audit Report

Purpose: Open DAO membership list with a compute function and ETH receiver.

Risk	Severity	SWC	OWASP
join() allows unlimited duplicate/Sybil membership entries	High	N/A	SC02 Business Logic
compute() has $O(n^2)$ loops and can become unusable through gas DoS	High	SWC-128	SC02 Gas/DoS
ETH can be received but no withdrawal/accounting mechanism exists	Medium	SWC-132	SC02 Financial Risks
No membership validation or cap on members array growth	Medium	N/A	SC05 Input Validation

Root Cause: Unbounded state growth and no uniqueness checks make membership and computation economically manipulable.

Business Logic Findings: Attackers can bloat the members array cheaply, breaking compute() and degrading governance reliability. Any received ETH may be permanently stuck.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.93 | Total_findings: 4

Critical: 0 | High: 2 | Medium: 2 | Low: 0

Precision_estimate: 0.91 | Coverage_estimate: 1.00 | Risk_score: 76/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A